Privacy Reconciliation — Updated Home & New Data Flows vs. the Privacy Corpus

> **Revised 2026-10-22 — historical gap register.** Many SEV-1 gaps below were closed after 2026-07-13: `/privacy` now discloses faith / minors / dependents, the device identifier, anti-fraud, Pabuya details (but not yet the new gift records), the payment-receipt read and most processors (Apple, Cloudflare Turnstile, Meta/Instagram sync and browser push services are still not named); face enrolment is adults-only. Vendor ID verification (Persona etc.) was retired 2026-07-03. For the current state read `NPC_Compliance/00_WHAT_CHANGED_2026-10-22.md` and the ROPA (DPS-01 → DPS-28).

Date: 2026-07-13 · **Type:** compliance deep-dive + gap register · **Status:** findings for owner/DPO/counsel — nothing silently changed
Trigger: owner — *"do a deep dive and track. most specially we updated our home."*
Method: 4-front audit — (1) redesigned couple **Home/Event Overview** data flows (worktree `feat/overview-council-redesign` @ `4eb39a329`, PR #3188), (2) new 2026-07-12 capture features + SPI/minor + build-state (grounded in `origin/main` migrations), (3) the live `setnayan.com/privacy` notice content, (4) the 9-doc privacy corpus for canonicity + conflicts. Load-bearing facts re-verified directly against `origin/main` before writing.

> **Headline.** Setnayan is **collecting sensitive personal information and minors' data in production, live, with disclosure gaps.** Profile **religion + civil status + gender** capture is live with no flag; the **dependents** table (minors' birth-date + religion + sex + godparent third-party emails) is recorded as flag-ON in prod (DECISION_LOG 2026-07-13); the onboarding **`events.signature_details`** path collects a child's DOB/gender and a pregnancy due-date with **no flag and no consent stamp**; and the couple **Home** now renders explicit religious-rite data. Meanwhile the **live privacy notice (last updated 2026-07-04)** mentions **none** of faith, minors, device-fingerprint, or e-gift handles — and **affirmatively denies collecting biometrics** while a biometric-enrollment feature is built. The freshest master dossier (2026-07-12) is the **narrowest** SPI declaration in the corpus and is **uncommitted**.

A. LIVE-NOW gaps — SPI / minors / financial PI collected in prod, undisclosed (SEV-1)

Ranked by exposure. "Live" = shipped on `origin/main` with capture reachable in production.

#	Data collected	Where	RA 10173 class	Build state (verified)	Disclosed anywhere?
1	**Religion + civil status + gender** (self)	`users.religion` / `civil_status` / `sex` (+ `*_consent_at`)	(!) SPI §3(l) — religion & marital status; sex sensitive-adjacent	**LIVE, no flag**, consent-stamped. `profile/actions.ts` writes directly (verified `origin/main`). Gender added today (PR #3209).	[X] Notice/dossier §5 list only biometrics as SPI

2	**Dependents** — minor's `birth_date` + `sex` + `religion`; **godparent name + email** (3rd party); godchild-birthday emails to that 3rd party	`dependents`, `godparents`	(!)(!) Minor + SPI + third-party PII	**Shipped; flag `NEXT_PUBLIC_DEPENDENT_PEOPLE` default OFF in code, but DECISION_LOG 2026-07-13 records owner set it `=1` in prod ("long done").** If so → **collecting now**; godchild emails go live next deploy. Household RLS shares a child's record with the spouse and **persists after annulment/separation** (owner rule B6).	[X] Zero [illegible] amendment (07-05) still says person-graph is *"adults-only… minors not processed"* — now contradicted
3	**Onboarding specialty fields** — christening `child_birth_date` + `child_gender`; gender-reveal **pregnancy `due_date`**; `ceremony_rite/rite_type` (religion); birthday `celebrant_age`	`events.signature_details` JSONB	(!) Minor + minor's sex + health-adjacent (pregnancy) + religion	**LIVE, NO flag, NO consent stamp.** With all 14 event types enabled (#3127), a christening/gender-reveal create-flow accepts these today. Gender-reveal `due_date` **contradicts the council's own Q3 "defer due-date capture until counsel clears."**	[X] Not disclosed; **collectable outside the counsel gate that governs the parallel `dependents` table**
4	**Explicit religious-rite data on the couple HOME** — Muslim nikah overlay (`mahr_description` free-text dower, `gender_separation`, `wali/witness/imam` guest roles), Chinese/Tsinoy tea-ceremony tile	`events.*`, `guests.role`, surfaced by Overview overlays	(!) SPI §3(l) religion	**LIVE** — rendered on `/dashboard/[eventId]` Home	[X] Notice never mentions tea ceremony as a data category

5	**Biometric face enrollment** — selfie + mandatory biometric-consent flow; `face_vector` column exists	`guest_face_enrollments`	(!) SPI §13 biometric	**Built.** Code comment: vector is **DORMANT** (image-only enrollment until an embedder/model is live) → selfies + consent captured now, vectors not yet stored.	(!) **Notice affirmatively DENIES it** — lists *"Face biometrics or any other biometric data"* under **"What we do not collect."** Denial is currently technically-true-for-vectors but false the moment the model ships, and the consent/table already exist
6	**Pabuya e-gift handles** — couple's own `gcash/maya/bank/paypal` handle + `account_name` + receiving-QR image	`event_egift_methods`	(!) Financial PI (not §13 SPI); display-only by design (no amount/ledger column)	**Table LIVE**; public guest route `PABUYA_PUBLIC_ROUTE_ENABLED=1` in prod per DECISION_LOG 2026-07-13	[X] **Zero mentions in all 9 privacy docs** — largest fully-undocumented processing activity

Data-minimization note (home): the Overview server component loads **full guest rows** — email, mobile, `dietary_restrictions`/`meal_preference` (health-adjacent), and `photo_consent`/`faceblock_enabled`/`face_recognition_excluded` (biometric-adjacent) — into memory even though only aggregate counts render. Co-host/invitee **email addresses are displayed** in the Hosts card, read via the RLS-bypassing admin client. Not a disclosure gap, but a minimization item worth a pass.

What bounds the exposure (good news): on the *home surface specifically*, dependents/minors' Year-view data is **flag-off and its commits are not in the redesign branch** (year-view code asserts "zero PII, no birthdates"), and **no e-gift handle is surfaced on any home surface**. So gaps #2 and #6 are live in their own routes, not additionally leaked onto Home.

B. Doc-corpus conflicts & staleness to reconcile (SEV-2/3)

The corpus is **four layers, no single canonical doc**. Deepest/most complete = the **tracked `NPC_Compliance/` pack** (11-system RoPA + DPIAs). The shiny **`NPC_Privacy_Compliance_Dossier_2026-07-12.md`** is the freshest executive summary but the **narrowest** SPI declaration — treat it as a summary annex, not the filing backbone.

- **Device-fingerprint "is it live?" — direct conflict.** New dossier §4 + `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12` say flag-OFF / collects nothing. But `01_Contracts/Anti_Fraud_Privacy_Policy_Amendment_DRAFT_2026-07-08` B.1 says *"we analyse signals we already hold: your device fingerprint… already active (shipped 2026-07-07)"* and DPO Designation B.5 lists it "live 2026-07-07." **Reconcile before either publishes.**
- **Dossier's PIA claims the fingerprint disclosure was "published in the public privacy notice 2026-07-12."** The live notice is dated **2026-07-04** and contains **no** device-fingerprint language. The claim is unsupported by the page.
- **SPI under-count in the new dossier.** §5 names only biometric vectors. The NPC pack treats **vendor gov-ID + liveness + AMLC/PEP sanctions** as the SPI categories that *trigger NPC registration* — the new dossier drops the entire vendor-verification surface. Filing the dossier as-is would under-declare.

- **DPO contact split.** New dossier → `dpo@setnayan.com`; every other doc → `iscasasolaii@gmail.com`. Two published DPO addresses. (DPO **identity** is consistent everywhere: the proprietor, Indalecio S. Casasola II — no doc names "Claire.")
- **Response-SLA split.** Dossier says **15 business days**; Privacy Policy §9 + DPO Designation say **7 business days**.
- **Retention — binding policy is stale.** `Setnayan_Privacy_and_Security_Policy.md` §4 has **no 10-year floor** (5y/7y model) and contradicts the newer `Data_Retention_Schedule_2026-07-11` (10-yr floor on payments/OR + contracts). The schedule's own §4 flags a **live gap**: account hard-delete **leaves chat PII behind**. Vendor-verification retention (90d hot → 7y cold) exists in the policy but is **absent from both the new schedule and the dossier ROPA**.
- **Subprocessor list omissions.** `/privacy` names **Persona** + **Anthropic** as cross-border recipients but leaves them **out of the Subprocessors table**; **Suno** (music generation) is missing from policy §10.
- **Cookie consent is `localStorage`-only** (`setnayan-cookie-consent-v1`) — no server-side consent-events log, which weakens RA 10173 proof-of-consent retention.
- **Stale one-pager.** `Setnayan_AI_Data_Use_DPO_Review_2026-06-29` frames the AI as a *paid* assistant learning from *browsing behavior*; current direction is **deterministic + free** — the behavioral-personalization framing reads stale.
- **Durability risk.** The three newest/most-relied-on docs — **dossier (07-12), retention schedule (07-11), fingerprint one-pager (07-12)** — are **UNTRACKED (uncommitted)**, i.e. the current "canonical" master + retention authority are the least-durable files in the set.

C. Owner / DPO / counsel decision queue (NOT actioned here — surfaced per corpus rules)

These are load-bearing and/or legal; I did not change the notice, the dossier, or any flag.

1. **Confirm the prod flag reality.** DECISION_LOG asserts `NEXT_PUBLIC_DEPENDENT_PEOPLE=1` and `PABUYA_PUBLIC_ROUTE_ENABLED=1` are ON in Vercel prod (unverifiable from the repo). If ON, the dossier must add a **live SPI+minors** processing activity (dependents) and a **financial-PI** activity (e-gift), incl. the household RLS spread + post-dissolution retention.
2. **Close the `signature_details` SPI hole.** Either gate the christening `child_birth_date`/`child_gender`, gender-reveal `due_date`, and `ceremony_rite` fields the same way the `dependents` table is gated, or attach equivalent consent copy + retention. The un-flagged due-date field directly contradicts the council's own defer recommendation.
3. **Fix the biometric denial.** The notice's "we do not collect biometrics" is a landmine given `guest_face_enrollments` + consent flow exist and vectors go live when the embedder ships. Rewrite to "optional, opt-in, per-event, currently image-only" rather than a flat denial.
4. **Publish the faith / minors / e-gift / device-fingerprint disclosures** in the public notice + add ROPA rows. These are the four categories the notice omits.
5. **Reconcile the corpus conflicts** in §B: pick one DPO email + one SLA; add the 10-yr floor + vendor-verification class to the binding policy; add Persona/Anthropic/Suno to the subprocessor list; resolve the device-fingerprint live/off contradiction; decide on a server-side consent log.
6. **External counsel sign-off** for the §3(l)/minors/third-party-notify cluster and the BSP-OPS e-gift question — the specs flagged *external* review as required; the owner-is-DPO marking resolves the internal step only.

D. What was tracked in this pass

- This document (the gap register).
- `DECISION_LOG.md` row (2026-07-13).
- Memory: `project_setnayan_privacy_reconciliation.md` + index pointer.
- The three previously-untracked privacy docs (dossier 07-12, retention schedule 07-11, device-fingerprint one-pager 07-12) committed into git history alongside this, so the canonical set is durable.

Not done (needs owner/DPO/counsel): editing the live `setnayan.com/privacy` notice (code-repo change + legal disclosure), or flipping any feature flag.

Correction — 2026-07-13: "dependents" is generic, not a minors registry

Owner: *a dependent "can be a dog, a cat, or anyone — there is no specification that it needs to be a child."* This audit (§A row 2, §C, and the "minors' data" framing throughout) over-characterized the `dependents` table as a minors registry. It is now a generic **"someone (or something) you care for"** list with a `dependent_kind` (person / pet / other) — app PR #3219. Only `kind=person` may carry a birth date / religion / sex under the age fence, and only there does minors' SPI arise (as a **conditional sub-case**, when the adult enters a child). Pets/other carry no sensitive data. Treat every "dependents = minors' data" statement in §A/§C as reframed by this note; the dossier §3/§5 and binding policy were updated to match.

Correction — 2026-07-13: the live notice was better than first reported

When the `/privacy` notice was edited (PR #3215), reading `origin/main` directly revealed the earlier extraction (agent, §A row 5 + §B) was from a **stale local checkout**: the deployed notice **already** carried a proper opt-in **Biometric** section (no "denies biometrics" line) **and** a **Device identifier (fraud prevention)** section. So gaps #5 (biometric denial) and the "notice omits device fingerprint" claim were **not real on the live site**. The genuine notice gaps were narrower — faith/family/honoree/e-gift + Anthropic/Suno — and those are what PR #3215 added. The dossier §5/§4/§11 were corrected to match. Treat §A row 5 and the §B "device-fingerprint disclosure" bullet as superseded by this note.

Update — 2026-07-13: dossier upgraded to a submittable v2.0

Owner: *"edit it and update so that will be the document we can submit NPC."* `NPC_Privacy_Compliance_Dossier_2026-07-12.md` was rewritten to **v2.0** and the `.docx` mirror regenerated. It now closes the **document-side** gaps from §A/§B: the ROPA (§3) covers all 18 processing activities incl. self-profile religion/civil/gender, the dependents/godparents family graph, event honoree/`signature_details` data, e-gift handles, and vendor-verification identity; the SPI declaration (§5) enumerates every sensitive category (was biometric-only); the subprocessor list (§7) adds Persona/TikTok/Suno; retention aligns to the 07-11 schedule's statutory floors. Owner decisions applied: **device fingerprint = OFF/dormant**; **minors' `signature_details` SPI = documented as-is**; DPO contact `dpo@setnayan.com` + 15-day SLA (matching the live surfaces). A consolidated **§11 "Open items before filing"** carries the residue: external counsel review (the final gate — this is a DPO draft, not legal advice), the **public `/privacy` notice** reconciliation (add faith/minors/e-gift/fingerprint disclosures + fix the biometric denial), and the older-corpus alignment (gmail→dpo@, 7→15-day SLA, 10-yr floor + vendor class + Persona/TikTok/Suno into the binding policy). **Still not done — needs owner/counsel:** the notice edit and external legal sign-off.